Calidad de Software aplicada al TFG

Trabajo Práctico Integrador · OptiFull, módulo de interfaz web

Calidad de Software · Mag. Pablo Virgolini

Integrantes: Blason Agostina · Nahmias Arnon · Ortiz Paulina

Nivel declarado: Nivel 3, prototipo avanzado

Entrega: 26 de octubre de 2026

Repositorio: github.com/pauliiortizz/OptiFull · carpeta `Proyecto Calidad/`

1. Contexto, alcance y nivel declarado

OptiFull es el Trabajo Final de Grado del equipo: una plataforma que analiza el video de las cámaras de un local (una estación de servicio con tienda) para obtener métricas de circulación, mapas de calor y alertas de posible hurto, y que identifica los productos en la caja para descontar stock. Está formada por tres procesos que se comunican solo a través de una base de datos compartida en Supabase: el pipeline de video, el pipeline de caja y el **módulo de interfaz web**.

Este TP aplica un proceso de calidad completo a un módulo: el **módulo de interfaz web** (`frontend/` en el repositorio). Lo forman el backend web, una API Flask (módulo 6 del informe de la tesis), y el panel web en React (módulo 7), con el dashboard, los reportes, las alertas, la caja web, la landing y el login. Se eligió porque es la única parte de OptiFull expuesta a internet, la que usa el personal del local todos los días y la que se conecta con los sistemas externos. Los otros dos procesos se siguen probando y midiendo en el mismo pipeline, pero no forman parte del TP.

Nivel declarado: Nivel 3 (prototipo avanzado). El sistema está desplegado en Render, con un entorno de QA y otro de producción; usa Supabase como base de datos en la nube, y el flujo principal funciona de punta a punta.

Integración externa. El módulo se conecta con Supabase (Postgres y Storage), con Render (hosting) y con Resend (aviso por email de los pedidos de demo). Cada integración tiene su contrato, sus pruebas con dobles y contra el servicio real, y su paso en el pipeline (sección 4.7 y `integracion-externa.md`).

Todo lo del TP está en la carpeta `Proyecto Calidad/` del repositorio: un documento por eje de la consigna, el plan de pruebas versionado, el registro de defectos y los documentos de apoyo. Este informe resume esos documentos; los números coinciden con el pipeline de GitHub Actions y con SonarQube Cloud.

2. El proceso de calidad en el pipeline

El pipeline (`.github/workflows/pipeline.yml`) va de lo más rápido y barato a lo más lento y costoso. Si una etapa falla, se corta ahí y no se despliega lo que sigue.

Etapa	Qué hace	Cuándo
build-test	Compila, Ruff (bloquea errores probables), 798 pruebas unitarias del módulo con cobertura, persistencia contra un Postgres temporal, lint y build del panel	Cada push, también a la rama de trabajo (1,6 min de media)
calidad	Análisis de SonarQube Cloud y quality gate propio	Push a `main`
system-check	Comprueba la base de QA, construye la imagen Docker y corre las pruebas de integración contra el contenedor	Push a `main`
deploy-qa	Despliega en Render el commit exacto y espera a que lo esté corriendo	Push a `main`
integration-qa	Smoke y pruebas de integración contra QA	Push a `main`
e2e-qa	Recorrido de un usuario con Playwright y Chromium	Push a `main`
carga-qa	Stress y esfuerzo sostenido con Locust, con umbrales	Push a `main`
deploy-prod	Despliega en producción el mismo commit y corre el smoke	Push a `main`

- **Ejecución completa en verde:** github.com/pauliiortizz/OptiFull/actions/runs/39657822881
- **Ejecución fallida que detectó un problema real:** …/runs/39643083288. El stress de 40 usuarios dio un p95 de 7,6 s: la API abría una conexión nueva a Supabase en cada pedido.

- **Otra:** .../runs/39495492793. El quality gate frenó código nuevo del panel que había llegado sin tests (73 % de cobertura sobre código nuevo).

3. Evolución de las métricas

La línea base es el commit ef77d4e (20/10/2026), cuando se incorporaron el análisis estático y el quality gate, antes de escribir los tests.

Medida (módulo web)	Línea base	Final (21/10)
Pruebas de la API	casi ninguna	441
Pruebas del panel	7 (un solo archivo)	367
Cobertura de la API (sentencia + decisión)	26 %	98,0 %
Cobertura del módulo en SonarQube Cloud	—	94,5 % (líneas 96,8 %, ramas 90,2 %)
Cobertura sobre código nuevo (proyecto)	—	86,5 %
Duplicación del módulo	—	1,0 % (pero 19,7 % en `video.py`)
Bugs críticos / vulnerabilidades abiertas	— / 10	0 / 0 (calificación de seguridad A)
Defectos encontrados y corregidos	—	20, todos con su test de regresión
Stress de 40 usuarios en QA: p95 / mediana	7 600 ms / 1 500 ms	2 400 ms / 100 ms
Carga sostenida de 15 usuarios en QA: p95	—	140 ms
Funciones con complejidad ciclomática > 10	7	8 (sin cambios de fondo)

Lo que más cambió fueron la cobertura, la cantidad de defectos encontrados y el desempeño bajo carga. La complejidad no cambió: las funciones complejas ya existían, quedaron cubiertas por tests pero no se refactorizaron.

4. Los ejes de la consigna

4.1 Introducción a la calidad

Los objetivos se fijaron desde tres miradas, cada uno con umbral, práctica que lo sostiene y valor medido (`01-introduccion-calidad.md`):

Mirada	Ejemplos de objetivos	Cumplidos
Usuario	p95 ≤ 2 s con la carga esperada (140 ms); nunca datos inventados; 0 errores de JavaScript en el recorrido; todo usable con teclado	3 de 4 (falta accesibilidad: quedan 11 observaciones)
Equipo	Cobertura ≥ 80 % (94,5 %); feedback en ≤ 5 min (1,6 min); 100 % de defectos con regresión (20 de 20); 0 bugs críticos	4 de 4
Organización	0 deploys sin verificar; 0 endpoints con datos sin sesión; 0 USD de costo; volver al verde en menos de un día	3 de 4 (la primera vez tardó 26 h)

El **plan de contingencia** cubre la caída de cada dependencia: cómo se detecta, qué ve el usuario, la respuesta inmediata y la recuperación. Supabase caído: la API responde 503 y el panel muestra "—", y se suspenden los deploys. Render caído: se levanta la misma imagen Docker en la PC del local. GitHub o SonarQube caídos: no se despliega, porque el gate falla cerrado. Armándolo apareció un riesgo nuevo: si el email de los pedidos de demo falla, el pedido queda solo en el disco de Render, que se borra en cada deploy (riesgo R9, abierto).

4.2 Fundamentos del testing

Las pruebas siguen el patrón **Arrange – Act – Assert**. El **criterio de aceptación se fija antes de ejecutar**: los umbrales del stress se escribieron antes de la primera corrida en QA y, cuando no se cumplieron, no se aflojaron: se buscó la causa y se mejoró el sistema. Cada defecto tiene su **contraste rojo/verde**: el test se ve fallar antes del arreglo. Para DEF-002, la API que entregaba el `.env` del servidor, el contraste quedó en el pipeline: …/runs/39466050826 en rojo y …/runs/39466216477 en verde.

Los **siete principios** se vieron en el TP. Con la API al 98 % de cobertura, el análisis estático igual encontró 5 vulnerabilidades (las pruebas muestran presencia de defectos, no su ausencia). Los defectos se concentraron en cuatro archivos de la API que reciben rutas y URLs del usuario (agrupamiento). Hicieron falta pruebas de otro tipo para encontrar lo que los tests unitarios ya no encontraban: la carga y el E2E (paradoja del pesticida). Y con todo en verde, el stress daba 7,6 s (falacia de la ausencia de errores).

4.3 Modelos de calidad y niveles de prueba

Matriz ISO/IEC 25010 con el formato del caso Knight Capital (`03-modelos-calidad-y-niveles.md`):

Característica	¿Comprometida?	Evidencia	Estado
Adecuación funcional	Sí	PDF que fallaba con algunas versiones de fpdf2; videos y clips con 500; un 0 % inventado	✅
Eficiencia de desempeño	Sí	p95 de 7,6 s bajo stress	✅ con el pool de conexiones
Compatibilidad	Sí	Sin Web Animations no se podía iniciar sesión	✅
Usabilidad	Parcial	Menú sin teclado; mensajes confusos; detalle por hora solo con el mouse	🟡
Fiabilidad	Sí	500 sin base de datos; Dashboard en blanco ante un error	✅
Seguridad	Sí	`.env` descargable; API sin login; SSRF, oráculo de archivos, clickjacking	✅ 0 vulnerabilidades
Mantenibilidad	Parcial	8 funciones con complejidad mayor a 10	🟡
Portabilidad	No	La misma imagen corre en CI, QA y producción	✅

Top 3: Seguridad (los dos defectos críticos, y el módulo está en internet con datos de personas), Fiabilidad (el personal depende del panel y Supabase no lo controlamos) y Eficiencia de desempeño (la que la carga mostró más comprometida y la que llevó a la mejora más grande).

Niveles de prueba: componente (798 pruebas unitarias), integración (22, con Postgres real, el contenedor y QA), sistema (E2E contra QA) y aceptación (E2E por rol, umbrales de carga y smoke en producción). **Despliegue verificado en cada instancia:** contenedor en CI, QA y producción corren el mismo commit, y el pipeline lo comprueba en cada una.

4.4 Métricas y análisis estático

Ocho métricas interpretadas (`04-metricas-y-analisis-estatico.md`), con dónde se concentra cada una. Lo más relevante:

- **Densidad de defectos:** 3,7 defectos por KLOC en la API frente a 1,0 en el panel. La API recibe los datos del usuario, y ahí se concentró la revisión de seguridad.
- **Duplicación:** 1,0 % en el módulo, pero 19,7 % en `video.py`. Un promedio bajo esconde concentraciones.
- **Complejidad:** `generar_pdf()`, con ciclomática 21 y cognitiva 40, está en el rango de alto riesgo.

Métrica de proceso: 2 de 8 ejecuciones de `main` en verde (25 %), y ninguna de las 6 fallas llegó a producción. Tres eran del producto, dos de los propios tests y una fue una hipótesis descartada con datos. El tiempo para

volver al verde fue de 26 h la primera vez y de 2 h después. **Métrica de proyecto:** desvío del cronograma de −67 % (se planificaron seis días y se usaron dos).

Hallazgos priorizados:

- **H1:** elementos con clic sin teclado (accesibilidad).
- **H4:** pedidos de demo que se pueden perder.
- **H2:** duplicación en `video.py`.
- **H3:** complejidad de `generar_pdf()`.

Flujo de control, encontrado sin ejecutar el código:

- Una rama defensiva de `_stream_video()` que no se puede cumplir, porque `_rango_pedido()` ya garantiza el rango. La cobertura lo confirma: es una de sus líneas sin cubrir.
- Un `border: 0` que nunca se aplica, porque la propiedad está repetida en el mismo objeto y la segunda lo pisa.

Mejora medida antes y después: el pool de conexiones a Supabase.

Stress, 40 usuarios en QA	Pedidos	Mediana	p95	p99	Resultado
4 hilos, una conexión por pedido	2 205	1 500 ms	7 600 ms	13 000 ms	❌
8 hilos (hipótesis descartada)	2 141	1 600 ms	8 200 ms	14 000 ms	❌
4 hilos, pool de conexiones	3 508	100 ms	2 400 ms	9 400 ms	✅

4.5 Pruebas dinámicas

Casos documentados con la plantilla IEEE 829 (`05-pruebas-dinamicas.md`):

- **Clases de equivalencia:** los parámetros de los clips de video (6 clases) y la fuente de la caja web (8 clases, 4 válidas y 4 no válidas).
- **Valores límite:**
- El bloqueo del login: con 4 fallos todavía entra; con 5 se bloquea; a los 301 s se desbloquea. El segundo 300 quedó como pregunta abierta del requisito.
- La cabecera `Range` en el último byte del archivo y en el primero fuera de él.
- **Tabla de decisión:** qué sección del panel ve cada rol (5 reglas).
- **Transición de estados:** el formulario de pedido de demo (5 caminos más una transición inválida) y el bloqueo del login.
- **Casos de uso:** los recorridos del administrador y del empleado.
- **Cobertura:** de sentencia 96,8 % y de decisión 90,2 % en el módulo.

4.6 Aseguramiento de la calidad

El **plan de pruebas** está versionado (va por la 3.0) y tiene criterios de entrada, de salida y de suspensión, riesgos y trazabilidad requisito → caso → defecto. **Riesgos:** 9 de producto y 5 de proyecto, priorizados en una matriz de probabilidad × impacto. Los más altos son las dependencias externas (16), la exposición de datos (15) y Supabase caído (15).

QA y QC. Son QA: los umbrales del gate, el plan, la regla de escribir primero el test que falla, la elección de la herramienta y traer `main` antes de cada PR. Son QC: las pruebas, la carga, el análisis estático, el registro en Jira y la verificación en el pipeline. Hay un ejemplo de lo que el QC no ve sin QA: el E2E pasa en cada deploy, pero con la cuenta de empleado, así que el recorrido del administrador no se prueba en QA. Ningún test va a fallar por eso; es una decisión del proceso.

Plantillas de caso y de defecto, con trazabilidad. **Ciclo de vida de un defecto:** "corregido" no es "verificado". Un defecto se cierra en Jira recién cuando el pipeline pasa con su test.

4.7 Automatización del testing

Pirámide: 798 pruebas unitarias y de componentes, 22 de API e integración, 2 E2E y 2 perfiles de carga. Las **pruebas de API** usan pytest y `requests` (el papel de Postman y Newman en la clase) contra el contenedor y contra QA en Render con Supabase. El **smoke** corre después de cada deploy, a QA y a producción. Hay **un test de regresión por cada uno de los 20 defectos**. **Punto de equilibrio** estimado: unos 11 deploys; entre el 20 y el 21/10 el pipeline corrió 50 veces. No se automatizan la usabilidad ni las pruebas exploratorias.

4.8 Herramientas del ecosistema

Categoría	Herramientas
Gestión de pruebas y defectos	Jira (proyecto KAN) y el plan versionado en el repositorio
Análisis estático	SonarQube Cloud, Ruff, oxlint
Ejecución y registro	pytest, Vitest + Testing Library, Playwright, requests
Cobertura	pytest-cov, V8
Rendimiento	Locust
CI/CD	GitHub Actions, Docker, Render
Diseño / BDD y pruebas específicas	No se usan, con su justificación

Herramienta nueva: SonarQube Cloud, incorporada con los cinco pasos:

1. Requisitos.
2. Mercado: SonarQube Cloud, SonarQube autoalojado, Codacy y DeepSource.
3. Prueba de concepto: encontró un defecto real.
4. Matriz de decisión ponderada: SonarQube Cloud 4,85 · Codacy 4,00 · DeepSource 4,00 · SonarQube autoalojado 3,80.
5. Despliegue incremental en cinco etapas, hasta el gate bloqueante.

Stress y esfuerzo sostenido en cada deploy, con umbrales (sección 3).

5. Metas del Nivel 3: cumplidas y no cumplidas

Aspecto	Exigido	Estado
Pipeline	Compilación, pruebas, análisis estático, cobertura, gate y reporte automático	✅
Quality gate	Bloquea con bugs críticos, duplicación > 5 % o cobertura nueva < 80 %	✅ Bloqueó dos veces; hoy en OK
Cobertura sobre código nuevo	80 %	✅ 86,5 %
Cobertura sobre código existente	80 %	✅ 94,5 %
Plan de pruebas y riesgos	Versionado, criterios, P × I, trazabilidad	✅
Defectos	Con pasos, esperado y obtenido, vinculados en Jira	✅ 20 en Jira
Herramienta nueva	Cinco pasos	✅ SonarQube Cloud
Smoke test	Ejecutado por el pipeline tras el despliegue	✅ En QA y en producción
Integración externa	Flujo E2E automatizado en cada despliegue	✅ Con la limitación de la cuenta de empleado

Aspecto	Exigido	Estado
Stress y esfuerzo sostenido	Ejecutado, con resultados y umbrales	✅

Las 10 metas se cumplen. Quedaron sin cumplir o parciales:

- El E2E del administrador no corre en QA.
- La accesibilidad con teclado (11 observaciones).
- Recuperar el verde en menos de un día la primera vez.
- La complejidad, que no bajó.
- El riesgo R9 de los pedidos de demo.
- La revisión de los PR por otro integrante.

6. Análisis crítico

Qué funcionó.

- **Cada falla tuvo una causa.** El pipeline frenó seis veces y ninguna falla llegó a producción. Ninguna se resolvió aflojando un criterio; cada una dejó un cambio en el sistema o en los tests.
- **Medir antes de optimizar.** La primera hipótesis para el stress (más hilos) era razonable y estaba mal, y la prueba de carga lo mostró en una corrida. Sin umbrales fijados de antemano, la diferencia entre 7,6 y 8,2 s se habría leído como ruido.
- **Combinar técnicas.** Los tests unitarios, el análisis estático, el E2E y la carga encontraron defectos de tipos distintos, y ninguna técnica por sí sola los habría encontrado todos.

Qué no funcionó, o no del todo.

- **Los tests también tienen defectos.** Dos de las seis fallas de `main` eran supuestos equivocados de los propios tests: la cuenta de administrador y la carrera del logout. Un test que falla por un error suyo cuesta lo mismo que uno que falla por el producto.
- **Los promedios esconden.** El gate mide la duplicación del proyecto (0,8 %) y no ve el 19,7 % de `video.py`.
- **La calidad interna no mejoró.** La cobertura subió mucho, pero las funciones complejas siguen igual. Están protegidas por tests, pero cada cambio en los reportes sigue siendo caro.
- **El proceso tiene una persona en el medio.** Los PR los mergea quien trabaja en la rama, y las cuentas de los servicios dependen de un integrante (riesgo RP4).

Qué quedó pendiente y por qué.

- **Los pedidos de demo en Supabase (R9) y la accesibilidad (H1):** son cambios del código de la tesis, y el TP no la modifica.
- **La cuenta de administrador en QA:** requiere crear un usuario en la base de QA y cargarlo en los secrets.
- **Los refactors de `video.py` y `generar_pdf()`:** se priorizaron por debajo, porque ya tienen tests que los protegen.

Sobre el uso de IA. Se usó un asistente como copiloto para los borradores de tests, scripts y documentos. Tres de sus propuestas fallaron en el pipeline y el proceso las detectó: el E2E de administrador, los 8 hilos y la carrera del logout. Es la mejor evidencia de que la IA no reemplaza al proceso de calidad: es una fuente más de cambios que el proceso tiene que verificar (`uso-de-ia.md`).

7. Conclusiones

1. El módulo de interfaz web cumple las **10 metas del Nivel 3**. Cada cambio se prueba automáticamente, desde el commit hasta producción; las integraciones externas (Supabase y Render) se prueban contra el servicio real en cada despliegue, y las decisiones se apoyan en datos.

2. El proceso encontró **20 defectos reales** en el módulo, dos de ellos críticos de seguridad. Todos se corrigieron con su test de regresión, y ninguno se encontró en producción.
3. La mejora más grande no vino de escribir más tests sino de **medir**: la prueba de carga descubrió que la API abría una conexión por pedido, y el pool de conexiones bajó la mediana del stress de 1 500 a 100 ms.
4. Un pipeline en verde no es lo mismo que un sistema de calidad. Cobertura alta y gate en OK convivieron con 19,7 % de duplicación en un archivo, con funciones de complejidad alta y con un riesgo de pérdida de datos. Las métricas y el análisis crítico son los que muestran lo que los tests no buscan.
5. El proceso queda funcionando para el resto de la tesis: cualquier cambio futuro al módulo pasa por las mismas pruebas, los mismos umbrales y el mismo registro de defectos.

Anexo: dónde está cada cosa

Qué	Dónde (en el repositorio)
Índice del TP y cruce con los entregables	`Proyecto Calidad/README.md`
Un documento por eje	`Proyecto Calidad/01-…` a `08-…`
Plan de pruebas versionado	`Proyecto Calidad/plan-de-pruebas.md`
Registro de defectos	`Proyecto Calidad/defectos.md` y Jira, proyecto KAN (optifull.atlassian.net)
Integración externa	`Proyecto Calidad/integracion-externa.md`
Herramienta incorporada y matriz de decisión	`Proyecto Calidad/herramienta-sonarcloud.md`
Pruebas de carga y resultados	`Proyecto Calidad/pruebas-de-carga.md`
Pipeline	`.github/workflows/pipeline.yml`
Código de las pruebas	`test/unitarios`, `test/bd`, `test/integracion`, `test/e2e`, `test/carga`, `frontend/src/**/*.test.*`
Análisis estático	sonarcloud.io, proyecto `pauliiortizz_OptiFull`